

Edit Profile & Voice Verification — API Test Report

Project: Hima (Android app) · Environment: <https://demohima.himaapp.in/api/auth> · Tested by: Perumal (QA) · Date: 2026-04-22 13:20

1. Executive summary

I ran 42 API test cases covering the two screens' five endpoints — /user_validations, /avatar_list, /update_profile, /speech_text, /update_voice — across functional, validation, security, boundary and performance categories.

42 Total tests	32 Passed	10 Failed	4 Critical	3 High	3 Medium
-------------------	--------------	--------------	---------------	-----------	-------------

2. Who needs to fix what

Every failure was classified by where the fix actually closes the hole. A fix belongs to the **server** if a curl-wielding attacker would bypass any client-side guard.

Android only 0 No bug is purely client-fixable — the app is well-behaved.	Android + Backend 1 Voice upload size cap — client should limit recording duration; backend must enforce byte cap.	Backend only 9 - Fix IDOR on /update_profile, /update_voice, /user_validations — use JWT sub, not body user_id. - Add auth middleware on /avatar_list, /speech_text. - Replace HTTP 500 crashes with JSON error responses. - Add FormRequest validators (name, interests, file size).
--	---	--

Bottom line: 10 of 10 bugs need backend work. 0 can be closed by Android alone.

3. Bugs — plain-language breakdown

CRITICALBUG-EP-005FIX: SERVEREdit Profile

/user_validations — IDOR: validate another user's id

What's wrong	Anyone logged in can validate a name as if they were a different user.
Why it matters	Lets an attacker probe which user IDs exist and what names are taken on other accounts.
How to fix	Backend: take the user_id from the login token, ignore the one sent in the request body.
Server response observed	<code>{"success":true,"message":"Name is valid."}</code>

MEDIUMBUG-EP-008FIX: SERVEREdit Profile

/avatar_list — no auth header

What's wrong	The avatar list API works without a login token at all.
Why it matters	Low severity, but any scraper can pull the whole avatar catalogue without signing in. Reduces attack surface to have one consistent auth policy.
How to fix	Backend: put this route behind the same auth middleware as the rest.
Server response observed	<code>{"success":true,"message":"Male avatar listed successfully.","total":9,"data":[{"id":22,"gender":"male","image":"","updated_at":"2025-04-01 12:04:29","created_at":"2024-12-01 19:51:25"}, {"id":23,"gender":"male","image":""}</code>

CRITICALBUG-EP-015FIX: SERVEREdit Profile

/update_profile — happy path (clean name + 1 interest)

What's wrong	Update-profile is crashing with HTTP 500 'Server Error' (plain Laravel error page) instead of returning a clean JSON error.
Why it matters	Critical for UX: the app shows the generic 'please try again later' toast instead of the real reason (e.g. 'you can change your name only once'). Also leaks the framework identity to anyone probing the API.
How to fix	Backend: wrap the 'name change only once' check in a proper validator / try-catch and return {success:false, message:'...'} JSON — never a 500 HTML.
Source ref	app/src/main/java/com/gmwapp/hima/activities/EditProfileActivity.kt:240-246
Server response observed	<code>{ "message": "Server Error" }</code>

CRITICALBUG-EP-010FIX: SERVEREdit Profile

/update_profile — IDOR: update foreign user_id

What's wrong	A logged-in user can overwrite another user's profile (name, avatar, interests) by sending a different user_id.
Why it matters	CRITICAL. This is close to account takeover — attacker can wipe, impersonate or defame any user with a single API call.
How to fix	Backend: derive user_id from the login token, not from the request body. Apply to every endpoint that takes user_id.
Source ref	app/src/main/java/com/gmwapp/hima/activities/EditProfileActivity.kt:241
Server response observed	<code>{ "message": "Server Error" }</code>

HIGHBUG-EP-011FIX: SERVEREdit Profile

/update_profile — missing name field

What's wrong	/update_profile — missing name field
Why it matters	Without a 'required' rule, missing field becomes empty string in DB and wipes the display name.
How to fix	Validator: <code>`name` => 'required string min:4 max:30'.</code>
Server response observed	<code>{"success":true,"message":"User details updated successfully.","data":{"id":456976,"name":"tXzDs689","user_gender":"male","language":"Tamil","mobile":"9876543210","avatar_id":21,"image":"","gender":"male"}}</code>

MEDIUM BUG-EP-013 FIX: SERVER Edit Profile

/update_profile — 30 interests (limit should be 5 per UI)

What's wrong	The server accepts 30 interests, even though the app UI caps at 5.
Why it matters	Medium. Bloats profile data; users from patched APKs or curl can pollute recommendation features that read the interests column.
How to fix	Backend: validate interests as an array with max 5, only from the known allow-list.
Server response observed	{ "message": "Server Error" }

HIGH BUG-VV-002 FIX: SERVER Voice Verification

/speech_text — no auth header

What's wrong	The speech-text API (which returns the sentence the user must read aloud) works without a login token.
Why it matters	Anyone can scrape the entire prompt catalogue. That makes it easy to bot / automate the voice-verification step.
How to fix	Backend: route must require auth.
Server response observed	{"success":true,"message":"Speech Text listed successfully.,"total":10,"data":[{"id":4,"text":"\u0b8e\u0ba9\u0bcd \u0bb5\u0bbe\u0bb4\u0bcd\u0bb5\u0bbf\u0ba9\u0bcd \u0baa\u0bca\u0bb0\u0bc1\u0bb3\u0bcd \u0ba8\u0bc0","lang

CRITICAL BUG-VV-006 FIX: SERVER Voice Verification

/update_voice — IDOR: upload voice for a different user_id

What's wrong	A logged-in user can replace someone else's voice recording by passing a different user_id. Test confirmed we actually overwrote another user's voice.
Why it matters	CRITICAL. Voice verification is the gating step for female creators. This lets someone sabotage a rival creator (replace their voice with gibberish → they get flagged / de-verified).
How to fix	Backend: derive user_id from the JWT only. Same pattern as BUG-EP-010.
Source ref	app/src/main/java/com/gmwapp/hima/activities/VoiceIdentificationActivity.kt:146
Server response observed	{"success":true,"message":"Voice uploaded successfully. Your profile is pending admin verification.,"data":{"id":456975,"name":"NisdB403","user_gender":"male","avatar_id":22,"image":"","gender":"male","language":"Tamil"

MEDIUM BUG-VV-008 FIX: BOTH Voice Verification

/update_voice — 10 MB file (mime/size guard)

What's wrong	The server accepts a 10 MB upload on /update_voice — no size limit observed.
Why it matters	Medium. Storage-DoS risk — an attacker can upload gigabytes of junk over time and inflate S3 bills.
How to fix	Client: cap recording duration. Backend: add 'max:10240' (10 MB) validator + nginx body-size guard.
Server response observed	{"success":true,"message":"Voice uploaded successfully. Your profile is pending admin verification.,"data":{"id":456976,"name":"tXzDs689","user_gender":"male","avatar_id":21,"image":"","gender":"male","language":"Tamil"

4. Full test matrix (42 cases)

ID	Screen	Test	Sev	Status	HTTP	Detail
EP-UV-01	Edit Profile	/user_validations — valid user_id + clean name → success	INFO	PASS	200	msg='Name is valid.'
EP-UV-02	Edit Profile	/user_validations — 3-char name should be rejected (UI enforces >=4)	MEDIUM	PASS	200	rejected
EP-UV-03	Edit Profile	/user_validations — empty name should be rejected	MEDIUM	PASS	200	'name is required.'
EP-UV-04	Edit Profile	/user_validations — 200-char name (overflow) should be rejected	MEDIUM	PASS	200	rejected · 'Name must be between 4 and 10 characters.'
EP-UV-05	Edit Profile	/user_validations — XSS/HTML injection name should be sanitized or rejected	HIGH	PASS	200	rejected or escaped
EP-UV-06	Edit Profile	/user_validations — SQL-like payload in name	HIGH	PASS	200	'Name must be between 4 and 10 characters.'
EP-UV-07	Edit Profile	/user_validations — IDOR: validate another user's id	CRITICAL	FAIL	200	accepted foreign user_id — IDOR (BUG-EP-005)
EP-UV-08	Edit Profile	/user_validations — no Authorization header	HIGH	PASS	401	HTTP 401
EP-UV-09	Edit Profile	/user_validations — emoji-only name '😄😄😄😄'	INFO	PASS	200	HTTP 200 · success=False
EP-UV-10	Edit Profile	/user_validations — leading/trailing whitespace	INFO	PASS	200	HTTP 200
EP-AV-01	Edit Profile	/avatar_list — gender=male returns non-empty list	INFO	PASS	200	total=9
EP-AV-02	Edit Profile	/avatar_list — gender=female returns non-empty list	INFO	PASS	200	total=1
EP-AV-03	Edit Profile	/avatar_list — invalid gender value	LOW	PASS	200	rejected
EP-AV-04	Edit Profile	/avatar_list — no auth header	MEDIUM	FAIL	200	HTTP 200 — avatar list exposed unauth (BUG-EP-008)
EP-AV-05	Edit Profile	/avatar_list — response under 2s (p95)	INFO	PASS	200	0.15s
EP-UP-01	Edit Profile	/update_profile — happy path (clean name + 1 interest)	CRITICAL	FAIL	500	HTTP 500 body={ "message": "Server Error" }
EP-UP-02	Edit Profile	/update_profile — avatar_id=999999 (not in avatar table)	MEDIUM	PASS	200	'avatar not found.'
EP-UP-03	Edit Profile	/update_profile — avatar_id='abc' (non-numeric)	MEDIUM	PASS	200	200
EP-UP-04	Edit Profile	/update_profile — IDOR: update foreign user_id	CRITICAL	FAIL	500	updated user None (BUG-EP-010)
EP-UP-05	Edit Profile	/update_profile — missing name field	HIGH	FAIL	200	accepted missing name → may blank out profile
EP-UP-06	Edit Profile	/update_profile — no Authorization header	HIGH	PASS	401	HTTP 401
EP-UP-07	Edit Profile	/update_profile — 30 interests (limit should be 5 per UI)	MEDIUM	FAIL	500	accepted 30 interests (BUG-EP-013) — msg='Server Error'
EP-UP-08	Edit Profile	/update_profile — interests containing non-whitelisted tag	MEDIUM	PASS	200	rejected
EP-UP-09	Edit Profile	/update_profile — second name change must return JSON error, not crash	HIGH	FAIL	500	HTTP 500 body={ "message": "Server Error" }
EP-UP-10	Edit Profile	/update_profile — response under 3s	INFO	PASS	500	0.18s
VV-ST-01	Voice Verification	/speech_text — valid user + language returns non-empty text	INFO	PASS	200	got text len=17
VV-ST-02	Voice Verification	/speech_text — unsupported language 'Klingon'	MEDIUM	PASS	200	rejected
VV-ST-03	Voice Verification	/speech_text — missing language param	MEDIUM	PASS	200	HTTP 200
VV-ST-04	Voice Verification	/speech_text — no auth header	HIGH	FAIL	200	HTTP 200 — endpoint unauthenticated (BUG-VV-002)

ID	Screen	Test	Sev	Status	HTTP	Detail
VV-ST-05	Voice Verification	/speech_text — IDOR: foreign user_id	HIGH	PASS	200	docs: returned generic prompt list
VV-ST-06	Voice Verification	/speech_text — response under 2s	INFO	PASS	200	0.14s
VV-UV-01	Voice Verification	/update_voice — small valid MP3 accepted	INFO	PASS	200	voice url saved
VV-UV-02	Voice Verification	/update_voice — empty file upload	MEDIUM	PASS	200	HTTP 200
VV-UV-03	Voice Verification	/update_voice — wrong MIME: PNG named voice.png	MEDIUM	PASS	200	HTTP 200
VV-UV-04	Voice Verification	/update_voice — no file part	MEDIUM	PASS	200	HTTP 200
VV-UV-05	Voice Verification	/update_voice — IDOR: upload voice for a different user_id	CRITICAL	FAIL	200	overwrote foreign user's voice id=456975 (BUG-VV-006)
VV-UV-06	Voice Verification	/update_voice — no auth header	HIGH	PASS	401	HTTP 401
VV-UV-07	Voice Verification	/update_voice — 10 MB file (mime/size guard)	MEDIUM	FAIL	200	10 MB upload accepted — storage DoS risk (BUG-VV-008)
VV-UV-08	Voice Verification	/update_voice — missing user_id field	INFO	PASS	200	HTTP 200
VV-UV-09	Voice Verification	/update_voice — response under 8s for small MP3	INFO	PASS	200	0.20s
VV-UV-11	Voice Verification	/update_voice — WAV file rejected (server enforces MP3)	INFO	PASS	200	rejected: 'Invalid voice file or Enter a Valid voice MP3 File required'
VV-UV-10	Voice Verification	/update_voice — path traversal filename	MEDIUM	PASS	200	safe (Laravel Storage regenerates name)

5. Methodology

- Tests authenticated with a real JWT obtained via /login for QA mobile 9876543210.
- IDOR tests use user_id = 1 to stay within valid DB range while probing cross-user access.
- Voice tests use synthesised silent MP3 / WAV fixtures — no real user voice recorded.
- Each request includes 200 ms spacing to avoid triggering throttle middleware.
- Profile mutated during the suite is restored to its original state at the end.